# INFORMATION SECURITY

**WyIT - 3003**

**PURPOSE:** This policy defines the mandatory minimum information security requirements for the State as defined below in the requirements section. Any affiliate may, based on its individual business needs and specific legal and federal requirements, exceed the security requirements put forth in this document but must, at a minimum, achieve the security levels required by this policy.

This policy defines the responsibility to:

- Protect and maintain the confidentiality, integrity, and availability of information and related infrastructure assets.
- Manage the risk of security exposure or compromise.
- Assure a secure and stable information technology (IT) environment.
- Identify and respond to events involving information asset misuse, loss, or unauthorized disclosure.
- Monitor systems for anomalies that might indicate compromise.
- Promote and increase awareness of information security.

Failure to secure and protect the confidentiality, integrity, and availability of information assets in today's highly networked environment can damage or shut down systems that operate critical infrastructure, financial and business transactions, and vital government functions. Compromised data can result in legal and regulatory non-compliance.

This policy benefits the State by defining a framework that will ensure appropriate measures are in place to protect the confidentiality, integrity, and availability of data. It will also ensure that staff and all other affiliates understand their roles and responsibilities, have adequate knowledge of security policies, procedures, and practices, and know how to protect information.

## I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as “agencies”). This policy is also applicable to consultants, affiliates, and temporary employees.

## II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

## III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

## IV. ORGANIZATIONAL SECURITY

- Information security requires both an information risk management function and an information technology security function. Depending on the affiliate's structure, an individual or group can serve in both roles or a separate individual or group can be designated for each role. It is recommended that these functions be performed by a high-level executive or a group that includes high-level executives.

- Each applicable agency or affiliate must designate an Agency Official for Privacy (AOP) (WyIT 2006, Agency Official for Privacy (AOP)) to be responsible for the risk management function assuring that:
  - Risk-related considerations for information assets and individual information systems, including authorization decisions, are viewed as an enterprise with regard to the overall strategic goals and objectives of carrying out its core missions and business functions
  - Management of information assets and information system-related security risks is consistent, reflects risk tolerance, and is considered along with other types of risks, to ensure mission and business success.
  - Each affiliate must designate an individual or group to be responsible for the technical information security function. For purposes of clarity and readability, this policy will refer to the individual or group designated as the affiliate-designated agency security liaison and the State CIO. This function will be responsible for evaluating and advising on information security risks.

    - Information security risk decisions must be made through consultation with both function areas described above.
- Although the technical information security function may be outsourced to affiliates, each affiliate retains overall responsibility for the security of the information that it owns.
- Information Classification and Handling shall be conducted in accordance with the Data and Privacy Policy WyIT - 2001 Information Classification.
- All information that is created, acquired, or used in support of State activities must only be used for its intended State purpose.
- All information assets must have an information owner established within the lines of business.
- Information must be properly managed from its creation through authorized use to proper disposal.
- All information must be classified on an ongoing basis based on its confidentiality, integrity, and availability characteristics.
- An information asset must be classified based on the highest level necessitated by its data elements.
- If the affiliate is unable to determine the confidentiality classification of information or the information is personal identifying information (PII), it must have a confidential classification and, therefore, be subject to confidential controls.
- Merging of information that creates a new information asset or situations that create the potential for merging (e.g., backup copies with multiple files) must be evaluated to determine if a new classification of the merged data is warranted.
- All reproductions of information in its entirety must carry the same confidentiality classification as the original. Partial reproductions need to be evaluated to determine if a new classification is warranted.
- Each classification has an approved set of baseline controls designed to protect these classifications, and these controls must be followed.
- The affiliate must communicate the requirements for secure handling of information to its workforce.
- A written or electronic inventory of all information assets must be maintained.
- Content made available to the general public must be reviewed according to a process that will be defined and approved by the affiliate. The process must include reviewing and approving updates to publicly available content and considering the type and classification of information posted.

- Personal Identifiable Information (PII) must not be made available without appropriate safeguards.
- For non-public information to be released outside the affiliate or shared between other affiliates, a process must be established that, at a minimum:
  - Evaluates and documents the sensitivity of the information to be released or shared.
  - Identifies the responsibilities of each party for protecting the information.
  - Defines the minimum controls required to transmit and use the information.
  - Records the measures that each party has in place to protect the information.
  - Defines a method for compliance measurement.
  - Provides a signoff procedure for each party to accept responsibilities.
  - Establishes a schedule and procedure for reviewing the controls.

## V. IT ASSET MANAGEMENT

- All IT hardware and software assets must be assigned to a designated agency or individual user.
- Affiliates are required to maintain an inventory of hardware and software assets, including all system components (e.g., network address, machine name, software version), at a level of granularity deemed necessary for tracking and reporting.
- Processes, including regular scanning, must be implemented to identify unauthorized hardware and/or software and notify appropriate staff. When discovered, the CIO will complete these processes and scans.

## VI. PERSONNEL SECURITY

- The workforce must receive general security awareness training (WyIT 3004, Security and Awareness Training and Education), to include recognizing and reporting insider threats, within 30 days of hire. Additional training on specific security procedures, if required, must be completed before access is provided to specific affiliate sensitive information not covered in the general security training. All security training must be reinforced at least annually and must be tracked by the affiliate.
- An affiliate must require its workforce to abide by the General Security - Acceptable Use policy (WyIT 3001, General Security - Acceptable Use) ,

and an auditable process must be in place for users to acknowledge that they agree to abide by the policy's requirements.

- All job positions must be evaluated by the Department of A&I and the applicable affiliate to determine whether they require access to sensitive information and sensitive information technology assets.
- For those job positions requiring access to sensitive information and sensitive information technology assets, affiliates must conduct workforce suitability determinations unless prohibited from doing so by law, regulation, or contract. Depending on the risk level, suitability determinations may include, as appropriate and permissible, evaluation of criminal history record information or other reports from federal, state, and private sources that maintain public and non-public records. The suitability determination must provide reasonable grounds for the affiliate to conclude that an individual will likely be able to perform the required duties and responsibilities of the subject position without undue risk to the affiliate.
- A process must be established within the affiliate to repeat or review suitability determinations periodically and upon change of job duties or position.
- Affiliates are responsible for ensuring all issued property is returned prior to an employee's separation, accounts are disabled, and access is removed immediately upon separation.

## VII. CYBER INCIDENT MANAGEMENT

- Affiliates must have an incident response plan to effectively respond to security incidents (WyIT 3010, Incident Response).
- All observed or suspected information security incidents or weaknesses are to be reported to appropriate management, the designated security security liaison, and the CIO as quickly as possible. If a member of the workforce feels that cyber security concerns need to be appropriately addressed, they may confidentially contact the State Cyber Security Operations Center directly (ets-security@wyo.gov).
- The State Cyber Security Operations Center must be notified of any cyber incident that may have a significant or severe impact on operations or security or that involves digital forensics to follow proper incident response procedures and guarantee coordination and oversight.

## VIII. PHYSICAL AND ENVIRONMENTAL SECURITY

- Information processing and storage facilities must have a defined security perimeter and appropriate security barriers and access controls.
- A periodic risk assessment must be performed for information processing and storage facilities to determine whether existing controls are operating correctly and if additional physical security measures are necessary. These measures must be implemented to mitigate the risks.
- Information technology equipment must be physically protected from security threats and environmental hazards. Special controls may also be necessary to protect supporting infrastructure and facilities such as electrical supply and cabling infrastructure.
- All information technology equipment and information media must be secured to prevent compromise of confidentiality, integrity, or availability in accordance with the classification of information contained therein.
- Visitors to information processing and storage facilities, including maintenance personnel, must be escorted at all times.

## IX. ACCOUNT MANAGEMENT AND ACCESS CONTROL

- All accounts must have an individual employee or group assigned to be responsible for account management. This may be a combination of the business unit and IT.
- Except as described in the Access Control policy (WyIT 3005, Access Control), access to systems must be provided through the use of individually assigned unique identifiers, known as user IDs.
- Associated with each user ID is an authentication token (e.g., password, key fob, biometric), which must be used to authenticate the identity of the person or system requesting access.
- Automated techniques and controls must be implemented to lock a session and require authentication or re-authentication after a period of inactivity for any system where authentication is required. Information on the screen must be replaced with publicly viewable information (e.g., screen saver, blank screen, clock) during the session lock.
- Automated techniques and controls must be implemented to terminate a session after specific conditions are met as defined in the Account Management/Access Control Standard.
- Tokens used to authenticate a person or process must be treated as

confidential and protected appropriately.

- Tokens must not be stored on paper or in an electronic file, hand-held device, or browser unless they can be stored securely and the method of storage (e.g., password vault) has been approved by the designated agency security liaison and CIO.
- Information owners are responsible for determining who shall have access to protected resources within their jurisdiction and what those access privileges shall be (read, update, etc.).
- Access privileges will be granted in accordance with the user's job responsibilities and will be limited only to those necessary to accomplish assigned tasks in accordance with affiliate missions and business functions (i.e., least privilege).
- Users of privileged accounts must use a separate, non-privileged account when performing normal business transactions (e.g., accessing the Internet, e-mail).
- Logon banners must be implemented on all systems where that feature exists to inform all users that the system is for business or other approved use consistent with policy, that user activities may be monitored, and that the user shall have no expectation of privacy.

## X. SYSTEM SECURITY

Systems include but are not limited to servers, platforms, networks, communications, databases, and software applications.

- An individual or group must be assigned responsibility for maintenance and administration of any system deployed on behalf of the affiliate. A list of assigned individuals or groups must be centrally maintained.
- Security must be considered at system inception and documented as part of the decision to create or modify a system.
- All systems must be developed, maintained, and decommissioned in accordance with a secure system development lifecycle (SSDLC).
- Each system must have a set of controls commensurate with the classification of any data that is stored on or passes through the system.
- All system clocks must synchronize to a centralized reference time source set to UTC (Coordinated Universal Time), which is itself synchronized with at least three synchronized time sources.
- Environments and test plans must be established to validate the system works as intended prior to deployment in production.

- Separation of environments (e.g., development, test, quality assurance, production) is required, either logically or physically, including separate environmental identifications (e.g., desktop background, labels).
- Formal change control procedures (WyIT 1001, Agency Controlled Information Technology (IT) Change Management and Maintenance) for all systems must be developed, implemented, and enforced. At a minimum, any change that may affect the production environment and/or production data must be included.
- Databases and Software (including in-house or affiliate developed and commercial off the shelf (COTS):
    - All software written for or deployed on systems must incorporate secure coding practices, to avoid the occurrence of common coding vulnerabilities and to be resilient to high-risk threats, before being deployed in production.
    - Once test data is developed, it must be protected and controlled for the life of the testing in accordance with the classification of the data.
- Production data may be used for testing only if a business case is documented and approved in writing by the information owner and the following controls are applied:
    - All security measures, including but not limited to access controls, system configurations, and logging requirements for the production data, are applied to the test environment, and the data is deleted as soon as the testing is completed. Sensitive data is masked or overwritten with fictional information.
- Where technically feasible, development software and tools must not be maintained on production systems.
- Where technically feasible, source code used to generate an application or software must not be stored on the production system running that application or software.
- Scripts must be removed from production systems, except those required for the operation and maintenance of the system.
- Privileged access to production systems by development staff must be restricted.
- Migration processes must be documented and implemented to govern the transfer of software from the development environment up through the production environment.

## XI. NETWORK SYSTEMS

- Connections between systems must be authorized by the executive management of all relevant affiliates and protected by the implementation of appropriate controls.
- All connections and their configurations must be documented, and the documentation must be reviewed by the information owner, the designated agency security liaison, and the CIO annually, at a minimum, to ensure:
    - The business case for the connection is still valid, and the connection is still required.
    - The security controls in place (filters, rules, access control lists, etc.) are appropriate and functioning correctly.
- A network architecture must be maintained that includes, at a minimum, tiered network segmentation between:
    - Internet-accessible systems and internal systems.
    - Systems with high-security categorizations (e.g., mission-critical systems containing Personal Identifiable Information) and other systems.
    - User and server segments.
- Network management must be performed from a secure, dedicated network.
- Authentication is required for all users connecting to internal systems.
- Network authentication is required for all devices connecting to internal networks.
- Only authorized individuals or business units may capture or monitor network traffic.
- A risk assessment must be performed in consultation with the designated agency security liaison and the CIO before the initiation of, or significant change to, any network technology or project, including but not limited to wireless technology.

## XII. COLLABORATIVE COMPUTING DEVICES

- Collaborative computing devices must:

    - prohibit remote activation; and
    - provide users physically present at the devices with an explicit indication of use.
- Must provide simple methods to physically disconnect collaborative computing devices.

## XIII. VULNERABILITY MANAGEMENT

- All systems must be scanned for vulnerabilities before being installed in production and periodically thereafter.
- All systems are subject to periodic penetration testing.
- Penetration tests are required periodically for all critical environments/systems.
- Where the affiliate has outsourced a system to another affiliate or a third party, vulnerability scanning/penetration testing must be coordinated.
- Scanning/testing and mitigation must be included in affiliate agreements.
- The output of the scans/penetration tests will be reviewed in a timely manner by the system owner. Copies of the scan report/penetration test must be shared with the designated security liaison and the CIO for evaluation of risk.
- Appropriate action, such as patching or updating the system, must be taken to address discovered vulnerabilities. For any discovered vulnerability, a plan of action and milestones must be created and updated accordingly to document the planned remedial actions to mitigate vulnerabilities.
- Any vulnerability scanning/penetration testing must be conducted by individuals who are authorized by the designated security liaison and the CIO. The CIO must be notified in advance of any such tests. Any other attempts to perform such vulnerability scanning/penetration testing will be deemed an unauthorized access attempt.
- Anyone authorized to perform vulnerability scanning/penetration testing must have a formal process defined, tested, and followed at all times to minimize the possibility of disruption.

## XIV. OPERATIONS SECURITY

- All systems and the physical facilities in which they are stored must have documented operating instructions, management processes, and formal

incident management procedures related to information security matters, which define the roles and responsibilities of affected individuals who operate or use them.

## XV. SYSTEM CONFIGURATIONS MUST FOLLOW APPROVED CONFIGURATION STANDARDS

- Advance planning and preparation must be performed to ensure the availability of adequate capacity and resources. System capacity must be monitored on an ongoing basis.
- Where the affiliate provides a server, application or network service to another affiliate, operational and management responsibilities must be coordinated by all impacted affiliates.
- Host-based firewalls must be installed and enabled on all workstations to protect from threats and to restrict access to only what is needed.
- Controls must be implemented (e.g., anti-virus, software integrity checkers, web filtering) across systems where technically feasible to prevent and detect the introduction of malicious code or other threats.
- Controls must be implemented to disable automatic execution of content from removable media.
- Controls must be implemented to limit storage of information to authorized locations.
- Controls must be in place to allow only approved software to run on a system and prevent execution of all other software.
- All systems must be maintained at an affiliate-supported level to ensure accuracy and integrity.
- All security patches must be reviewed, evaluated and appropriately applied in a timely manner. This process must be automated, where technically possible.
- Systems which can no longer be supported or patched to current versions must be removed.
- Systems and applications must be monitored and analyzed to detect deviation from the access control requirements outlined in this policy and the Security Logging Standard, and record events to provide evidence and to reconstruct lost or damaged data.
- Audit logs recording exceptions and other security-relevant events must be produced, protected, and kept consistent with record retention schedules and requirements.

- Monitoring systems must be deployed (e.g., intrusion detection/prevention systems) at strategic locations to monitor inbound, outbound and internal network traffic.
- Monitoring systems must be configured to alert incident response personnel to indications of compromise or potential compromise.
- Contingency plans (e.g., business continuity plans, disaster recovery plans, continuity of operations plans) must be established and tested regularly.
- An evaluation of the criticality of systems used in information processing (including but not limited to software and operating systems, firewalls, switches, routers and other communication equipment).
- Recovery Time Objectives (RTO)/Recovery Point Objectives (RPO) for all critical systems.
- Backup copies of affiliate information, software, and system images must be taken regularly in accordance with the affiliate's defined requirements.
- Backups and restoration must be tested regularly. Separation of duties must be applied to these functions.
- Procedures must be established to maintain information security during an adverse event. For those controls that cannot be maintained, compensatory controls must be in place.

## REFERENCES

- WyIT 1001. Agency Controlled Information Technology (IT) Change Management and Maintenance
- WyIT 2001 - Information Classification
- WyIT 2006 - Agency Official For Privacy (AOP)
- Wy 3001 - General Security - Acceptable Use
- WyIT 3004 - Security and Awareness Training and Education
- WyIT 3005 - Access Controls
- WyIT 3010 - Incident Response

# DOCUMENT HISTORY

| ORIGINAL SUBMISSION | | | | |
|---|---|---|---|---|
| **SUBMITTED ON** | **SUBMITTED BY** | **APPROVED BY** | **APPROVED BY DATE(S)** | **EFFECTIVE DATE** |
| June 2024 | ETS Governance, Risk and Compliance | Public Comment Period | 05/10/2024 - 05/24/2024 | June 2024 |
| | | | | |
| | | | | |

| REVISIONS | | |
|---|---|---|
| **LAST REVISION DATE** | **LAST REVISED BY** | **LAST APPROVED BY** |
| | | |
| | | |
| | | |

| REVIEWS | | |
|---|---|---|
| **LAST REVIEW DATE** | **LAST REVIEWED BY** | **NEXT REVIEW DATE** |
| | | |
| | | |
| | | |